MITM Attack Analysis and Network Hardening Using HTTPS and SSH Certificates

Prepared by : Jerusalem Madessa

Disclaimer

This assessment was conducted in a controlled environment to evaluate security risks and validate mitigation strategies. All activities were performed on authorized systems for defensive security purposes.

Executive Summary

This assessment evaluated the security posture of a web-based system by simulating a real-world Man-in-the-Middle (MITM) attack within a controlled network environment. The objective was to determine whether sensitive information, such as user credentials, could be intercepted during normal application use and to assess the effectiveness of various security controls in preventing such attacks.

During testing, it was observed that when the application was accessed over HTTP, user credentials were transmitted in plaintext and successfully intercepted using ARP spoofing techniques. This demonstrated a critical risk, as an attacker positioned within the network could capture sensitive information without detection. After enforcing HTTPS, the same attack was repeated, and although the attacker remained in a position to intercept traffic, the data was encrypted and no longer readable. This confirmed that encryption effectively protects data confidentiality even when network-level attacks are present.

Further analysis identified that the web server was running an outdated version of Nginx, which introduced additional risk due to known vulnerabilities. The service was upgraded to a secure version, reducing the likelihood of exploitation. In addition, access control mechanisms were strengthened by implementing certificate-based authentication and disabling traditional password and key-based login methods. This ensured that only trusted, centrally managed identities could access the system.

Overall, the assessment demonstrated how insecure configurations can lead to credential compromise and how layered security controls, including encryption, patch management, and centralized authentication can significantly improve system security and resilience.

Scope

This assessment was conducted in a controlled lab environment to evaluate the security posture of a simulated enterprise network. The scope included a client workstation and a web server within the 172.30.0.0/24 network. Testing focused on network communication, web application access, and remote administration services, specifically HTTP/HTTPS traffic and SSH access control mechanisms. All activities were performed on authorized systems.

Objectives

- Simulate a MITM attack using ARP spoofing
- Identify exposure of sensitive data over insecure protocols
- Mitigate risks using HTTPS encryption
- Perform vulnerability remediation through patch management
- Implement certificate-based SSH authentication
- Enforce centralized and secure access control

Tools Used

- **Ettercap** – ARP spoofing and traffic interception
- **Nginx** – Web server under assessment
- **OpenSSH** – Remote access service
- **Step CA** – Certificate authority for X.509 and SSH certificates
- **Linux CLI tools** – System configuration and validation
- **PowerShell** – Certificate and SSH key management

Methodology

The assessment followed a structured approach designed to simulate realistic attack scenarios, validate the exposure of sensitive data, and measure the effectiveness of implemented security controls.

The process began with network reconnaissance to establish a baseline understanding of the environment. Active hosts were identified, connectivity was verified, and ARP table entries were reviewed to observe normal network behavior. Establishing this baseline ensured that any subsequent anomalies could be clearly attributed to the attack simulation.

A Man-in-the-Middle (MITM) attack was then executed using ARP spoofing techniques. By poisoning the ARP cache of both the client and the web server, the attacker system positioned itself between the two endpoints, enabling interception and monitoring of traffic in transit. This phase focused on determining whether sensitive information, such as authentication credentials, could be captured during normal user interaction with the application.

Traffic analysis confirmed that HTTP communication transmitted credentials in plaintext, validating the risk of credential exposure. The methodology then transitioned to testing mitigation controls by enforcing HTTPS. The same interception technique was maintained to simulate an active attacker, allowing direct comparison between unencrypted and encrypted traffic. This ensured that the effectiveness of TLS encryption was validated under realistic adversarial conditions.

The assessment then moved to vulnerability management by examining the web server software. The Nginx version was identified as outdated and potentially vulnerable. A controlled upgrade was performed to a patched version, followed by verification to confirm successful remediation and reduced exposure to known exploits.

In the final phase, access control mechanisms were evaluated and strengthened. A certificate authority (CA) was used to issue X.509 identity certificates and SSH certificates, enabling centralized authentication. Traditional authentication methods, including password-based login and user-managed authorized_keys, were disabled to eliminate insecure access paths.

Authentication testing was then conducted to confirm that access was granted only when a valid CA-signed certificate was presented and denied in all other scenarios.

This methodology ensured that vulnerabilities were not only identified but also mitigated and validated through practical testing.

Key Findings

1. Credential Exposure via Unencrypted HTTP Communication

During the MITM simulation, user authentication data was transmitted over HTTP without encryption. By performing ARP spoofing, the attacker successfully intercepted network traffic between the client and the web server. Analysis of the captured traffic revealed that login credentials, including the username and password, were sent in plaintext and could be directly extracted.

This represents a critical security risk, as any attacker with access to the same network segment could intercept sensitive data without requiring advanced exploitation techniques. The lack of encryption exposes user credentials to theft, which could lead to unauthorized system access, privilege escalation, and lateral movement within the network.

Risk Level: High

2. Lack of Transport Layer Security (TLS)

The web application initially relied on HTTP (port 80), which provides no confidentiality, integrity, or authentication guarantees. As a result, data transmitted between the client and server was fully visible and modifiable by an attacker positioned in the network path.

This vulnerability significantly increases the attack surface, as it allows attackers to not only capture sensitive information but also potentially manipulate traffic in transit. Without TLS, the system is vulnerable to session hijacking, credential harvesting, and data tampering, all of which can compromise system integrity and user trust.

Risk Level: High

3. Outdated Web Server Software (Nginx 1.18.0)

The assessment identified that the web server was running Nginx version 1.18.0, which is outdated and associated with publicly disclosed vulnerabilities (e.g., CVE-2021-23017). Outdated software increases the risk of exploitation, as attackers can leverage known vulnerabilities to gain unauthorized access, execute malicious code, or disrupt services.

Failure to maintain up-to-date software exposes the system to avoidable risks and reduces the effectiveness of other security controls. This finding highlights the importance of regular patch management and vulnerability remediation practices.

Risk Level: Medium

4. Weak and Decentralized SSH Access Control Mechanisms

The system initially supported password-based authentication and allowed the use of user-managed authorized keys files for SSH access. These methods lack centralized control and introduce several security risks, including susceptibility to brute-force attacks, credential reuse, and unauthorized key persistence.

Additionally, the absence of a centralized identity verification mechanism makes it difficult to enforce consistent access policies or revoke access efficiently. This increases the likelihood of unauthorized access and reduces visibility into authentication activities.

Risk Level: Medium

Remediation Actions

- Enforced HTTPS to encrypt all web traffic
- Upgraded Nginx to a secure version (1.22.1)
- Implemented X.509 certificates for identity verification
- Introduced SSH certificate-based authentication

- Disabled password-based login
- Disabled authorized_keys to enforce centralized access control

Validation & Testing

- Credentials were no longer visible during MITM attacks over HTTPS
- SSH access without a certificate was denied
- Certificate-based authentication successfully granted access
- Unauthorized login attempts were blocked

Security Improvements

- Data transmission secured through encryption
- Exposure to known vulnerabilities reduced
- Authentication centralized and hardened
- Attack surface significantly minimized

Conclusion

This assessment demonstrated how insecure communication and outdated configurations can lead to credential compromise and increased risk of exploitation. By implementing encryption, performing patch management, and enforcing certificate-based authentication, the system's overall security posture was significantly improved. The applied controls aligned with modern security principles, including defense-in-depth and Zero Trust, resulting in a more secure and resilient environment.